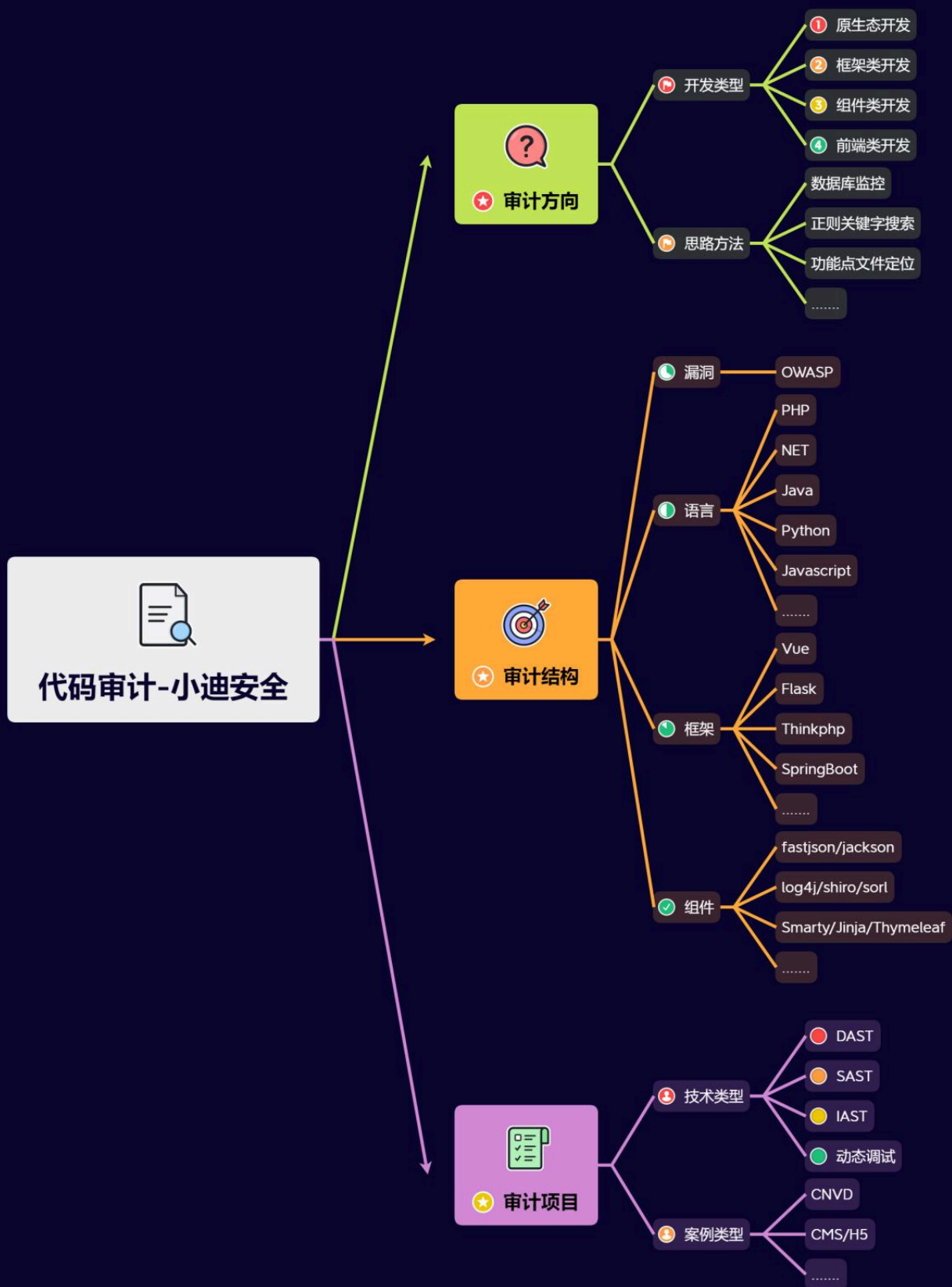


Day116 代码审计-ASP.NET开发篇&DLL反编译&动态调试&EXE逆向&鉴权逻辑&脆弱验证



1.知识点

- 1、PHP审计-原生态开发-SQL注入&语句监控
- 2、PHP审计-原生态开发-SQL注入&正则搜索
- 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-原生态开发-SQL注入&语句监控
 - 2、PHP审计-原生态开发-SQL注入&正则搜索
 - 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-MVC开发-RCE&代码执行
 - 2、PHP审计-MVC开发-RCE&命令执行
 - 3、PHP审计-MVC开发-RCE&文件对比

-
- 1、PHP审计-动态调试-未授权安全
 - 2、PHP审计-文件对比-未授权安全
 - 3、PHP审计-未授权访问-三种形态

-
- 1、PHP审计-动态调试-变量覆盖
 - 2、PHP审计-动态调试-原生反序列化
 - 3、PHP审计-动态调试-框架反序列化

-
- 1、PHP框架学习-ThinkPHP-架构&调试&路由&接受
 - 2、PHP框架审计-ThinkPHP-不安全写法&版本漏洞

-
- 1、PHP框架审计-ThinkPHP-反序列化链分析
 - 2、PHP框架审计-ThinkPHP-反序列化链挖掘

-
- 1、PHP框架审计-Yii-反序列化链分析
 - 2、PHP框架审计-Yii-实际CMS挖掘分析

-
- PHP代审项目-TP框架-实战某违法微盘

-
- 1、ASP.NET审计-SQL注入-继承架构&DLL反编译
 - 2、ASP.NET审计-SQL注入-数据库监控&关键字搜索

-
- 1、ASP.NET审计-文件上传-DLL反编译&关键字搜索
 - 2、ASP.NET审计-文件上传-预编译解析&关键字搜索
-

- 1、ASP.NET审计-未授权访问-未引用脆弱鉴权
 - 2、ASP.NET审计-未授权访问-不严谨鉴权逻辑
 - 3、ASP.NET审计-动态调试-附加进程&断点调试
 - 4、ASP.NET审计-程序逆向-EXE逻辑&修改覆盖
-

2.详细点

ASPX文件->CS ASPX.CS DLL反编译后寻找 看核心代码分析漏洞

CS ASPX.CS DLL反编译文件->ASPX文件寻找 确定漏洞进行调试测试

代码审计时要把这个反编译文件提取导入到IDE中 后期搜索关键字或函数挖掘

2.1 后缀解析

asp.net可以用C# , VB.NET , Jscript.net等等来开发,但是通常首选都是C#和VB.NET。审计asp.net的时候,首先得弄明白他的结构,他并不像php那么单纯。一般来说,在asp.net应用中,需要进行观察的文件

有: .aspx, .cs, .ashx, dll文件

- 1、.aspx是页面后的代码,aspx负责显示,服务器端的动作就是在.cs定义的
- 2、.cs是类文件,公共类神马的就是这个了
- 3、.ashx是一般处理程序,主要用于写web handler,可以理解成不会显示的aspx页面
- 4、.dll就是cs文件编译之后的程序集

2.2 指向解析

Inherits

msdn解释: 定义供页继承的代码隐藏类。它可以是从 Page 类派生的任何类。此特性与 CodeFile 特性一起使用,后者包含指向代码隐藏类的源文件的路径。 Inherits 特性在使用 C# 作为页面语言时区分大小写,而在使用 Visual Basic 作为页面语言时不区分大小写。

CodeFile

msdn解释: 指定指向页引用的代码隐藏文件的路径。此特性与 Inherits 特性一起使用,用于将代码隐藏源文件与网页相关联。此特性仅对编译的页有效。

Codebehind

msdn解释: 指定包含与页关联的类的已编译文件的名称。该特性不能在运行时使用。此特性用于 Web 应用程序项目。

3.演示案例

3.1 ASP.NET审计-未授权访问-未引用脆弱鉴权



- 1 未引用鉴权逻辑: MasterPageFile="/purchase/purchase.Master"
- 2 Default.aspx->purchase.Master->Purchase.Purchase.pur->UserHelper.GetUserId



- 1 脆弱的鉴权逻辑: userinfo=userid=1
- 2 Default.aspx->purchase.Master->Purchase.Purchase.pur->UserHelper.GetUserId->Request.Cookies["userinfo"]
- 3

3.2 ASP.NET审计-未授权访问-不严谨鉴权逻辑



- 1 不严谨鉴权逻辑: 类似过滤器监听器功能
- 2 App_global.asax->App_web_global.asax.cs.cdca7d2->Ufida.T.Web.Http.Global.Application_PreRequestHandlerExecute->?preload=1
- 3 App_global.asax->App_web_global.asax.cs.cdca7d2->Ufida.T.Web.Http.Global.Application_PreRequestHandlerExecute->IsBaseRequest

3.3 ASP.NET审计-动态调试-附加进程&断点调试



- 1 同PHP,JAVA等相似, 如何动态调试分析代码运行逻辑
- 2 参考: https://blog.csdn.net/qq_37213281/article/details/120058386

3.4 ASP.NET审计-程序逆向-EXE逻辑&修改覆盖



- 1 案例: WEB应用授权逆向&EXE程序数据修改
- 2 .NET平台开发的应用均可以修改逻辑代码后保存达到逆向绕过等